COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.2 · Risk Analysis

Mestre CyberSec · **Aula 5.2 — Risk Analysis** (9:13) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Análise: qualitativa (alto/médio/baixo) vs quantitativa ($ — SLE × ARO = ALE); risk appetite (o que a organização ACEITA — board define); risk tolerance (variação aceitável por área); risk register.

💡 Highlights que a prova CompTIA cobra

- ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo
- Appetite: o RISCO que aceita; tolerance: variação por área (operacional)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'accepting a specific risk level per business unit'=risk tolerance

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.2 — Risk Analysis)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Expectativa de Perda Única (SLE)

O valor monetário esperado de uma única ocorrência de um evento de risco. Calculado como Valor do Ativo × Fator de Exposição (EF).

⚠ ***Armadilha CompTIA:*** *SLE is NOT annualized — it is per-incident. If the question says 'per occurrence' or 'one event', it's SLE, not ALE.*

• Taxa de Ocorrência Anualizada (ARO)

A frequência estimada com que uma ameaça deve ocorrer em um único ano (ex.: 0,5 = uma vez a cada 2 anos, 4 = quatro vezes ao ano).

⚠ ***Armadilha CompTIA:*** *ARO can be a fraction. If a flood happens 'once every 5 years', ARO = 0.2 — this directly multiplies into the ALE formula.*

• Expectativa de Perda Anualizada (ALE)

A perda monetária esperada de um risco ao longo de um ano. Fórmula: ALE = SLE × ARO. Usada para justificar custos de controles de segurança na análise de custo/benefício.

⚠ ***Armadilha CompTIA:*** *ALE = SLE × ARO is the only formula to memorize for the exam. If a control costs less than the ALE, it is generally worth implementing.*

• Análise Qualitativa de Risco (N/A)

Uma avaliação de risco subjetiva e baseada em cenários que usa classificações como alto/médio/baixo ou vermelho/amarelo/verde em vez de valores monetários; baseia-se no julgamento de especialistas.

⚠ ***Armadilha CompTIA:*** *If the question mentions 'high/medium/low' or 'scenario-based' or 'subjective rating', it is qualitative — not quantitative. It does NOT produce dollar amounts.*

• Análise Quantitativa de Risco (N/A)

Uma avaliação de risco objetiva e numérica que atribui valores em dólares ao risco usando os cálculos de SLE, ARO e ALE.

⚠ ***Armadilha CompTIA:*** *Any question showing actual dollar/currency values or asking you to calculate SLE, ARO, or ALE is quantitative. Hard data vs. soft ratings is the key distinction.*

• Apetite ao Risco (N/A)

A quantidade e o tipo geral de risco que a organização está disposta a aceitar na busca de seus objetivos, definido no nível do conselho/diretoria.

⚠️ ***Armadilha CompTIA:*** *Appetite is set by the BOARD/senior leadership — it is the BROAD, organizational-level statement of acceptable risk (e.g., 'we will not accept risks that could cause bankruptcy').*

• Tolerância ao Risco (N/A)

A variação aceitável em relação ao apetite ao risco, geralmente definida por unidade de negócio, departamento ou sistema; mais granular e tática que o apetite.

⚠️ ***Armadilha CompTIA:*** *Exam phrase trigger: 'accepting a specific risk level per business unit' = risk TOLERANCE. Appetite = organization-wide, Tolerance = per business unit/department.*

• Registro de Riscos (N/A)

Um documento ou repositório central que lista os riscos identificados, sua probabilidade, impacto, responsável, status de mitigação e nível de risco residual.

⚠️ ***Armadilha CompTIA:*** *The risk register is the OUTPUT of the risk identification process and the input to ongoing risk monitoring. Know that it tracks ownership and mitigation progress.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Análise Qualitativa de Risco (Matriz de Probabilidade vs Impacto)

🏠 **Analogia Intuitiva:** A triagem de pronto-socorro em um grande hospital (Protocolo de Manchester): a enfermeira não gasta horas calculando equações matemáticas; ela avalia os sintomas e coloca uma fita vermelha (crítico/emergência imediata), amarela (urgente/médio) ou verde (baixo/pode aguardar). É rápida, visual e permite priorizar onde colocar os médicos imediatamente sem paralisar o atendimento.

🔍 **Causa Raiz / Por que foi criado:** A dificuldade de precificar com precisão monetária o impacto reputacional ou a probabilidade de ataques inéditos de dia zero, tornando a categorização qualitativa essencial para priorização ágil.

🛡️ **Visão do Auditor de GRC:** Avaliar a matriz de risco da empresa (geralmente 3x3 ou 5x5): verificar se os critérios de 'Alto', 'Médio' e 'Baixo' possuem definições operacionais objetivas para evitar que a análise se torne puramente subjetiva.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'uses descriptive, subjective terms such as High, Medium, Low to prioritize risks quickly without complex mathematical formulas' = Qualitative Risk Analysis.

📌 Expectativa de Perda Única (Single Loss Expectancy - SLE = AV × EF)

🏠 **Analogia Intuitiva:** O cálculo do prejuízo de uma batida lateral em um carro de R$ 100.000 (Valor do Ativo - AV). Se a colisão destrói a porta e a lateral amassando 25% do valor total do veículo (Fator de Exposição - EF = 0,25), o prejuízo daquela batida isolada para o bolso do proprietário é exatamente R$ 25.000 (SLE = R$ 100.000 × 0,25).

🔍 **Causa Raiz / Por que foi criado:** A necessidade de apresentar ao conselho de administração o custo financeiro concreto em dinheiro de um único incidente cibernético grave para justificar investimentos de defesa.

🛡️ **Visão do Auditor de GRC:** Validar os cálculos de SLE: conferir se o Asset Value inclui custos indiretos (reposição de hardware, horas de consultoria forense e multas legais) e se o EF é sustentado por estatísticas históricas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: fórmula 'SLE = Asset Value (AV) × Exposure Factor (EF)'. Se um ativo vale $500.000 e o EF é 20%, o SLE é $100.000.

📌 Expectativa Anualizada de Perda (Annualized Loss Expectancy - ALE = SLE × ARO)

🏠 **Analogia Intuitiva:** O cálculo da provisão anual para conserto de telhados atingidos por granizo. Se cada temporal com granizo causa R$ 20.000 de estrago no telhado (SLE = R$ 20.000) e o histórico meteorológico mostra que a cidade sofre em média 3 tempestades de granizo por ano (ARO = 3), a perda financeira esperada a cada ano é de R$ 60.000 (ALE = R$ 20.000 × 3 = R$ 60.000/ano).

🔍 **Causa Raiz / Por que foi criado:** A alta liderança exige comparar o custo financeiro anualizado de um risco com o valor da mensalidade de softwares de segurança ou apólices de seguro.

🛡️ **Visão do Auditor de GRC:** Auditar a razoabilidade da Taxa Anualizada de Ocorrência (ARO): se um evento acontece 1 vez a cada 2 anos, o ARO é 0,5; se acontece 4 vezes ao ano, o ARO é 4,0. Conferir a precisão da fórmula ALE = SLE × ARO.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: fórmula 'ALE = SLE × ARO'. Se a perda por incidente é $10.000 e espera-se que ocorra 5 vezes ao ano, o ALE é $50.000 anuais.

📌 Análise Custo-Benefício de Controles (Cost-Benefit Safeguard Analysis)

🏠 **Analogia Intuitiva:** Comprar uma trava antifurto blindada que custa R$ 5.000 por ano de manutenção para proteger uma bicicleta velha de R$ 100 guardada no quintal: a proteção custa 50 vezes mais do que o bem a ser protegido. Um controle de segurança só é viável se o custo de sua implementação for substancialmente menor do que o dinheiro que ele economiza em perdas anuais.

🔍 **Causa Raiz / Por que foi criado:** O desperdício de orçamento de TI em soluções caras que defendem ativos de baixo impacto ou riscos de probabilidade infinitesimal.

🛡️ **Visão do Auditor de GRC:** Calcular o valor econômico do controle: Valor do Controle = ALE (sem controle) - ALE (com controle) - Custo Anual do Controle. Se o resultado for negativo, recomendar rejeição do projeto ou busca de solução mais econômica.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'a safeguard should not cost more than the value of the asset it protects or the expected annual loss (ALE)' = Cost-Benefit Analysis / ROI of Security.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Equipe de risco classifica vulnerabilidades em matriz de cores Vermelho, Amarelo e Verde com base em opinião de especialistas	**Análise Qualitativa de Risco (Qualitative Risk Analysis)**
Servidor avaliado em $200.000 sofre impacto de 30% caso seja inundado por enchente, gerando prejuízo pontual de $60.000	**Expectativa de Perda Única (Single Loss Expectancy - SLE)**
Incidente que gera perda de $10.000 ocorre com frequência estimada de duas vezes por ano no parque de notebooks	**Taxa Anual de Ocorrência: ARO = 2,0 (Annualized Rate of Occurrence - ARO)**
Cálculo matemático multiplica o SLE ($40.000) pelo ARO (0,5) para obter a perda monetária média anual de $20.000	**Expectativa Anualizada de Perda (Annualized Loss Expectancy: ALE = SLE × ARO)**
Diretor recusa comprar firewall de $100.000 anuais porque o risco cibernético mitigado causa perdas anuais estimadas em apenas $15.000	**Análise Custo-Benefício de Salvaguarda (Safeguard Cost-Benefit Analysis)**
Porcentagem do ativo destruída ou comprometida caso uma ameaça específica seja bem-sucedida em explorar a falha	**Fator de Exposição (Exposure Factor - EF)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros está realizando uma análise quantitativa de risco para seu banco de dados de clientes. O banco de dados está avaliado em US$ 500.000. Uma violação bem-sucedida exporia 20% dos registros, e dados do setor indicam que esse evento é esperado uma vez a cada quatro anos. Qual é a perda anual esperada (ALE)?

A) US$ 100.000

B) US$ 125.000

C) US$ 25.000

D) US$ 500.000

QUESTÃO 2 · CENÁRIO DE EXAME

Um analista de risco está calculando a expectativa de perda única (SLE) para um servidor de folha de pagamento. O servidor tem valor de ativo de US$ 120.000. Se um ataque ransomware for bem-sucedido, a equipe estima que 35% do valor do servidor seria perdido. Qual é a SLE?

A) US$ 42.000

B) US$ 78.000

C) US$ 120.000

D) US$ 155.000

QUESTÃO 3 · CENÁRIO DE EXAME

Uma pequena startup não tem dados históricos confiáveis de perdas e precisa priorizar riscos de segurança cibernética rapidamente. O CISO pede que a equipe classifique cada risco como alto, médio ou baixo com base em probabilidade e impacto usando um mapa de calor. Que tipo de análise de risco está sendo usada?

A) Análise de perda anual esperada

B) Análise qualitativa de risco

C) Análise de impacto nos negócios

D) Análise quantitativa de risco

QUESTÃO 4 · CENÁRIO DE EXAME

O conselho de administração declara que a organização está disposta a aceitar risco moderado para acelerar a adoção da nuvem, mas não aceitará risco que possa afetar dados de segurança de pacientes. O que essa declaração define principalmente?

A) Tolerância a risco

B) Registro de riscos

C) Expectativa de perda única

D) Apetite a risco

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa tem apetite a risco geral moderado. No entanto, sua plataforma de comércio eletrônico não pode ficar indisponível por mais de 15 minutos, enquanto o sistema interno de RH pode ficar fora do ar por até 4 horas. O que essa diferença ilustra?

A) Tolerância a risco

B) Apetite a risco preservando a cadeia de custódia e a integridade forense

C) Taxa anual de ocorrência

D) Fator de exposição

QUESTÃO 6 · CENÁRIO DE EXAME

Após concluir uma avaliação de risco, um analista de GRC precisa documentar cada risco identificado, seu proprietário, probabilidade, impacto, pontuação, plano de tratamento e status atual. Onde essas informações devem ser registradas?

A) Inventário de ativos

B) Relatório de varredura de vulnerabilidades

C) Registro de riscos

D) Acordo de nível de serviço

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa calcula que um ataque a aplicação web tem SLE de US$ 50.000 e ARO de 2,0, produzindo um ALE de US$ 100.000. Após implementar um firewall de aplicação web, o ARO é reduzido para 0,5 enquanto o SLE permanece US$ 50.000. Qual é a redução da perda anual esperada?

A) US$ 25.000

B) US$ 50.000

C) US$ 100.000

D) US$ 75.000

QUESTÃO 8 · CENÁRIO DE EXAME

Um hospital deseja justificar gastos com segurança cibernética estimando a perda monetária anual esperada por ransomware. A equipe tem registros internos de incidentes e dados do setor sobre custos de violações. Qual abordagem melhor se ajusta a esse requisito?

A) Análise qualitativa de risco

B) Análise quantitativa de risco

C) Definição de apetite a risco fornecendo métricas quantitativas de risco para a diretoria

D) Manutenção do registro de riscos

QUESTÃO 9 · CENÁRIO DE EXAME

Um analista de risco está calculando a taxa anual de ocorrência (ARO) para uma inundação que dados históricos indicam acontecer uma vez a cada 20 anos. Qual ARO deve ser usado?

A) 0,05

B) 0,20

C) 5,0 para atender a normas regulatórias obrigatórias de governança

D) 20,0

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa identifica um achado de alto risco em seu portal do cliente. A equipe implementa um controle compensatório, reduzindo o risco a um nível residual baixo que a gestão aceita. O que o analista de risco deve fazer em seguida?

A) Remover o risco do registro de riscos porque um controle foi implementado fornecendo métricas quantitativas de risco para a diretoria

B) Encerrar o relatório de varredura de vulnerabilidades sem documentar a decisão para atender a normas regulatórias obrigatórias de governança

C) Alterar o apetite a risco para corresponder ao nível de risco residual dentro dos limites formais de apetite a risco da organização

D) Atualizar o registro de riscos com o risco residual, tratamento e status de aceitação

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — US$ 25.000

SLE = valor do ativo × fator de exposição = US$ 500.000 × 0,20 = US$ 100.000. ARO = 1 evento / 4 anos = 0,25. ALE = SLE × ARO = US$ 100.000 × 0,25 = US$ 25.000.

Questão 2: Alternativa A — US$ 42.000

SLE = valor do ativo × fator de exposição. Aqui, US$ 120.000 × 0,35 = US$ 42.000. Os outros valores não aplicam corretamente o fator de exposição.

Questão 3: Alternativa B — Análise qualitativa de risco

A análise qualitativa de risco usa classificações subjetivas como alto, médio e baixo, frequentemente com um mapa de calor, quando dados numéricos ou tempo são limitados. A análise quantitativa usa valores monetários e cálculos como SLE, ARO e ALE. A análise de impacto nos negócios concentra-se em funções críticas de negócio e requisitos de recuperação.

Questão 4: Alternativa D — Apetite a risco

Apetite a risco é a quantidade e o tipo gerais de risco que a organização está disposta a aceitar, e normalmente é definido pela alta liderança ou pelo conselho. Tolerância a risco é a variação aceitável em torno desse apetite para áreas ou sistemas específicos.

Questão 5: Alternativa A — Tolerância a risco

Tolerância a risco é o desvio aceitável do apetite a risco geral para um sistema, departamento ou processo específico. A empresa aceita risco moderado em geral, mas tolera níveis diferentes de risco de disponibilidade para sistemas diferentes.

Questão 6: Alternativa C — Registro de riscos

O registro de riscos é o registro central usado para acompanhar riscos identificados, proprietários, classificações, decisões de tratamento e status. O inventário de ativos lista ativos, relatórios de vulnerabilidades listam achados técnicos e SLAs definem compromissos de serviço.

Questão 7: Alternativa D — US$ 75.000

Antes do controle, ALE = US$ 50.000 × 2,0 = US$ 100.000. Após o controle, ALE = US$ 50.000 × 0,5 = US$ 25.000. A redução é US$ 100.000 – US$ 25.000 = US$ 75.000.

Questão 8: Alternativa B — Análise quantitativa de risco

A análise quantitativa de risco usa dados numéricos e monetários, como SLE, ARO e ALE, para estimar a perda anual esperada. Isso é apropriado quando dados históricos e do setor estão disponíveis e a justificativa orçamentária exige valores financeiros.

Questão 9: Alternativa A — 0,05

ARO é a frequência esperada por ano. Se um evento acontece uma vez a cada 20 anos, ARO = 1 / 20 = 0,05.

Questão 10: Alternativa D — Atualizar o registro de riscos com o risco residual, tratamento e status de aceitação

O registro de riscos deve ser atualizado para refletir o tratamento aplicado, o nível de risco residual, o proprietário e a aceitação pela gestão. Riscos não são simplesmente excluídos após mitigação porque o risco residual e as decisões de aceitação ainda precisam ser acompanhados.